

OWASP ZAP

Herramienta de seguridad para análisis de aplicaciones Web.

Qué es

ZAP es un proxy de seguridad open source para inspeccionar tráfico y apoyar pruebas Web.

Uso seguro

Use ambientes autorizados. Passive Scan observa tráfico; Active Scan envía ataques y requiere autorización explícita.

QA en pipeline

ZAP puede apoyar DAST automatizado en ambientes controlados con criterios para falsos positivos.

Cuándo utilizarlo

Utilice este conocimiento cuando el riesgo, la arquitectura o la etapa de entrega requieran este tipo de validación. Confirme objetivo, ambiente, datos necesarios y evidencias esperadas antes de comenzar.

Cómo lo aplica QA

Parta del comportamiento o riesgo que debe validarse, prepare datos y ambiente, ejecute la técnica o herramienta de forma reproducible y registre evidencias que ayuden al equipo a comprender el resultado.

Buenas prácticas

Priorice escenarios de mayor impacto, mantenga datos y ambientes controlados, registre decisiones importantes y revise periódicamente el enfoque para evitar cobertura redundante o desactualizada.

Consejo de QA

Relacione siempre la práctica con el riesgo del producto y la evidencia necesaria para decisiones de calidad.

Recursos oficiales

Site oficial: <https://www.zaproxy.org/download/>